

Part 1: Reconnaissance

Traffic Interception

I ran my pipeline with three terminals (broker, publisher, subscriber), then opened a fourth terminal and ran:

```
mosquitto_sub -t "#" -v
```

```
PS C:\Users\mahin\OneDrive\Documents\hydroficient-project> mosquitto_sub -t "#" -v
hydroficient/grandmarina/sensors/main-building/readings {"device_id": "GM-HYDROLOGIC-01", "location": "main-building", "pressure_upstream": 80.3364959517854, "pressure_downstream": 7
5.37976924391835, "flow_rate": 39.31206218684093, "timestamp": "2026-04-10T02:55:16.734588+00:00", "counter": 32}
hydroficient/grandmarina/sensors/main-building/readings {"device_id": "GM-HYDROLOGIC-01", "location": "main-building", "pressure_upstream": 84.95405505205136, "pressure_downstream":
75.38020866284043, "flow_rate": 41.46754308013165, "timestamp": "2026-04-10T02:55:18.736436+00:00", "counter": 33}
hydroficient/grandmarina/sensors/main-building/readings {"device_id": "GM-HYDROLOGIC-01", "location": "main-building", "pressure_upstream": 83.43275652275096, "pressure_downstream":
79.13174385760747, "flow_rate": 40.85005828214955, "timestamp": "2026-04-10T02:55:20.737739+00:00", "counter": 34}
hydroficient/grandmarina/sensors/main-building/readings {"device_id": "GM-HYDROLOGIC-01", "location": "main-building", "pressure_upstream": 80.46852290796191, "pressure_downstream":
77.22557647437064, "flow_rate": 38.73742147372458, "timestamp": "2026-04-10T02:55:22.739095+00:00", "counter": 35}
hydroficient/grandmarina/sensors/main-building/readings {"device_id": "GM-HYDROLOGIC-01", "location": "main-building", "pressure_upstream": 82.42196811397079, "pressure_downstream":
76.7641015980472, "flow_rate": 38.956674783112696, "timestamp": "2026-04-10T02:55:24.740035+00:00", "counter": 36}
hydroficient/grandmarina/sensors/main-building/readings {"device_id": "GM-HYDROLOGIC-01", "location": "main-building", "pressure_upstream": 80.40054311399122, "pressure_downstream":
77.7707731675772, "flow_rate": 40.91706447288805, "timestamp": "2026-04-10T02:55:26.741275+00:00", "counter": 37}
hydroficient/grandmarina/sensors/main-building/readings {"device_id": "GM-HYDROLOGIC-01", "location": "main-building", "pressure_upstream": 81.70250310350437, "pressure_downstream":
76.28682571014672, "flow_rate": 39.60090653583773, "timestamp": "2026-04-10T02:55:28.742741+00:00", "counter": 38}
hydroficient/grandmarina/sensors/main-building/readings {"device_id": "GM-HYDROLOGIC-01", "location": "main-building", "pressure_upstream": 84.87945707077617, "pressure_downstream":
75.99864429005021, "flow_rate": 41.87405243607486, "timestamp": "2026-04-10T02:55:30.745054+00:00", "counter": 39}
hydroficient/grandmarina/sensors/main-building/readings {"device_id": "GM-HYDROLOGIC-01", "location": "main-building", "pressure_upstream": 80.39002227891802, "pressure_downstream":
75.11805062849878, "flow_rate": 40.65915374128011, "timestamp": "2026-04-10T02:55:32.747638+00:00", "counter": 40}
hydroficient/grandmarina/sensors/main-building/readings {"device_id": "GM-HYDROLOGIC-01", "location": "main-building", "pressure_upstream": 82.11070560094917, "pressure_downstream":
79.65921544447616, "flow_rate": 38.233148326079416, "timestamp": "2026-04-10T02:55:34.749727+00:00", "counter": 41}
hydroficient/grandmarina/sensors/main-building/readings {"device_id": "GM-HYDROLOGIC-01", "location": "main-building", "pressure_upstream": 84.61751126299077, "pressure_downstream":
76.35371173549716, "flow_rate": 39.41029412484729, "timestamp": "2026-04-10T02:55:36.751424+00:00", "counter": 42}
hydroficient/grandmarina/sensors/main-building/readings {"device_id": "GM-HYDROLOGIC-01", "location": "main-building", "pressure_upstream": 82.38488574517653, "pressure_downstream":
79.2892153843783, "flow_rate": 40.49565357180112, "timestamp": "2026-04-10T02:55:38.752574+00:00", "counter": 43}
hydroficient/grandmarina/sensors/main-building/readings {"device_id": "GM-HYDROLOGIC-01", "location": "main-building", "pressure_upstream": 80.10060818490973, "pressure_downstream":
75.77539605104221, "flow_rate": 40.146979671641816, "timestamp": "2026-04-10T02:55:40.754659+00:00", "counter": 44}
hydroficient/grandmarina/sensors/main-building/readings {"device_id": "GM-HYDROLOGIC-01", "location": "main-building", "pressure_upstream": 82.33754009677357, "pressure_downstream":
78.2297360341653, "flow_rate": 39.6560042157266, "timestamp": "2026-04-10T02:55:42.755810+00:00", "counter": 45}
hydroficient/grandmarina/sensors/main-building/readings {"device_id": "GM-HYDROLOGIC-01", "location": "main-building", "pressure_upstream": 82.80292473957977, "pressure_downstream":
75.06807136082297, "flow_rate": 38.500997246524946, "timestamp": "2026-04-10T02:55:44.757007+00:00", "counter": 46}
hydroficient/grandmarina/sensors/main-building/readings {"device_id": "GM-HYDROLOGIC-01", "location": "main-building", "pressure_upstream": 83.43913996240933, "pressure_downstream":
77.46939237446375, "flow_rate": 39.22606257584031, "timestamp": "2026-04-10T02:55:46.758201+00:00", "counter": 47}
hydroficient/grandmarina/sensors/main-building/readings {"device_id": "GM-HYDROLOGIC-01", "location": "main-building", "pressure_upstream": 84.46251695479084, "pressure_downstream":
78.02748492191988, "flow_rate": 40.854489380508824, "timestamp": "2026-04-10T02:55:48.759480+00:00", "counter": 48}
hydroficient/grandmarina/sensors/main-building/readings {"device_id": "GM-HYDROLOGIC-01", "location": "main-building", "pressure_upstream": 81.97781485006746, "pressure_downstream":
75.29217644397608, "flow_rate": 41.15392131188548, "timestamp": "2026-04-10T02:55:50.761121+00:00", "counter": 49}
hydroficient/grandmarina/sensors/main-building/readings {"device_id": "GM-HYDROLOGIC-01", "location": "main-building", "pressure_upstream": 83.46436318840294, "pressure_downstream":
75.64267215316205, "flow_rate": 41.930463441105886, "timestamp": "2026-04-10T02:55:52.762801+00:00", "counter": 50}
hydroficient/grandmarina/sensors/main-building/readings {"device_id": "GM-HYDROLOGIC-01", "location": "main-building", "pressure_upstream": 81.12012647075015, "pressure_downstream":
78.46557970852858, "flow_rate": 40.837334370383545, "timestamp": "2026-04-10T02:55:54.764002+00:00", "counter": 51}
hydroficient/grandmarina/sensors/main-building/readings {"device_id": "GM-HYDROLOGIC-01", "location": "main-building", "pressure_upstream": 80.68851809957299, "pressure_downstream":
75.13561612515781, "flow_rate": 38.34479926228574, "timestamp": "2026-04-10T02:55:56.765331+00:00", "counter": 52}
hydroficient/grandmarina/sensors/main-building/readings {"device_id": "GM-HYDROLOGIC-01", "location": "main-building", "pressure_upstream": 83.03171003897609, "pressure_downstream":
79.22728371972315, "flow_rate": 40.40203215416444, "timestamp": "2026-04-10T02:55:58.766211+00:00", "counter": 53}
hydroficient/grandmarina/sensors/main-building/readings {"device_id": "GM-HYDROLOGIC-01", "location": "main-building", "pressure_upstream": 84.36195994200388, "pressure_downstream":
77.74501016528967, "flow_rate": 41.79246727031509, "timestamp": "2026-04-10T02:56:00.814099+00:00", "counter": 54}
hydroficient/grandmarina/sensors/main-building/readings {"device_id": "GM-HYDROLOGIC-01", "location": "main-building", "pressure_upstream": 84.56462455205228, "pressure_downstream":
77.83129213519187, "flow_rate": 39.17461058916804, "timestamp": "2026-04-10T02:56:02.817947+00:00", "counter": 55}
hydroficient/grandmarina/sensors/main-building/readings {"device_id": "GM-HYDROLOGIC-01", "location": "main-building", "pressure_upstream": 83.91182063731873, "pressure_downstream":
77.96170991873403, "flow_rate": 40.25134335903574, "timestamp": "2026-04-10T02:56:04.819538+00:00", "counter": 56}
hydroficient/grandmarina/sensors/main-building/readings {"device_id": "GM-HYDROLOGIC-01", "location": "main-building", "pressure_upstream": 82.14275783608177, "pressure_downstream":
75.32321656504877, "flow_rate": 39.75951197496748, "timestamp": "2026-04-10T02:56:06.820872+00:00", "counter": 57}
hydroficient/grandmarina/sensors/main-building/readings {"device_id": "GM-HYDROLOGIC-01", "location": "main-building", "pressure_upstream": 80.30342780546531, "pressure_downstream":
```

Results after 30 seconds of capture:

- Messages captured: 15 messages
- Topics observed:
 - o hydroficient/grandmarina/sensors/main-building/readings
- Information visible in each message:
 - o Device ID (e.g., GM-HYDROLOGIC-01)
 - o Location (e.g., main-building)
 - o Timestamp (full ISO format)
 - o Counter (sequence number)
 - o Pressure upstream (e.g., 82.3 PSI)
 - o Pressure downstream (e.g., 76.8 PSI)
 - o Flow rate (e.g., 40.1 gal/min)

Part 2: Vulnerability Analysis

Vulnerability	What's the Risk?	Evidence from My Pipeline	Potential Attack
No encryption	All data is transmitted in plain text. Anyone on the same network can read every message, including device readings and operational data.	I captured complete JSON messages showing pressure readings, flow rates, device IDs, and timestamps — all readable without any decryption.	An attacker on the hotel WiFi could passively monitor all sensor data and learn normal operating values to craft convincing fake readings later.
No authentication	Anyone can connect to the broker without providing credentials. There's no way to verify who is connecting or whether they should have access.	I connected to the broker using <code>mosquitto_sub</code> with no username, password, or certificate. The broker accepted my connection immediately.	A malicious actor could connect their laptop to the hotel network and immediately start receiving all sensor data — no hacking required, just one command.
No authorization	Even if someone connects, there are no rules about what topics they can access. Everyone can see everything and publish anywhere.	I subscribed to <code>#</code> (all topics) and received all messages across the entire pipeline with no restrictions.	An attacker could publish a fake emergency shutoff command to <code>hydroficient/grandmarina/commands/main-building/emergency_shutoff</code> , cutting water to the entire hotel.

Vulnerability	What's the Risk?	Evidence from My Pipeline	Potential Attack
No message verification	The subscriber accepts any message without checking if it's authentic, unmodified, or fresh. There's no signature, no integrity check, no timestamp validation.	My subscriber displayed every incoming message as if it came from a legitimate device — the system had no way to detect a spoofed payload.	An attacker could inject fake sensor readings showing normal pressure and flow values to hide an actual leak, or replay old messages to mask a real anomaly.

Part 3: Remediation Recommendations

1. What defenses would you add?

1. TLS Encryption

- a. Encrypt all traffic between clients and the broker so messages cannot be read in transit
- b. Standard approach: configure Mosquitto to require TLS connections

2. Client Authentication

- c. Require username/password or client certificates for all connections
- d. Only authorized devices and dashboards can connect
- e. Revoke credentials immediately if a device is compromised

3. Topic-Based Access Control Lists (ACLs)

- f. Define rules: Device GM-HYDROLOGIC-01 can only publish to sensors/main-building/readings
- g. Dashboards can subscribe but not publish to sensor topics
- h. Prevents unauthorized publishing and limits damage from compromised devices

4. Message Validation

- i. Check timestamps — reject messages older than 60 seconds
- j. Track counters — reject duplicate or out-of-sequence messages
- k. Consider adding message signatures (HMAC) for integrity verification

2. What's most urgent to fix?

Priority Ranking:

Rank	Vulnerability	Why This Priority
1	No authentication	This is the front door. Without authentication, none of the other controls matter — attackers can walk right in. Fix this first.
2	No encryption	Once we control who connects, we need to protect what they send. Sensor and operational data in plain text is a serious exposure.
3	No authorization	With authentication and encryption in place, we need to limit what authenticated users can do. Least privilege principle.
4	No message verification	This is defense in depth. Even with the above controls, we should validate messages to catch compromised devices or replay attacks.

3. What trade-offs might these defenses have?

Defense	Trade-off
TLS Encryption	Performance: Encryption adds CPU overhead and slight latency. For high-frequency sensors publishing every 2 seconds, this could cause delays. May need to upgrade hardware or batch messages.
Client Authentication	Complexity: Every device needs credentials. Managing certificates across multiple HYDROLOGIC devices requires a provisioning process. What happens when a certificate expires at 2 AM?
Access Control Lists	Maintenance: Rules must be updated when devices are added, moved, or removed. Complex ACL configurations can have gaps or conflicts. Testing is essential.
Message Validation	Clock Sync: Timestamp validation requires all devices to have synchronized clocks. Clock drift could cause legitimate messages to be rejected. NTP configuration is needed.